

Information Security Policy

Organization: Techno Optics LLC (operating Taxottic) **Document version:** 1.0 **Effective date:** 2026-05-04
Owner: Information Security Lead, Techno Optics LLC **Review cadence:** Quarterly (next review: 2026-08-04)

1. Purpose

This Information Security Policy ("Policy") establishes the principles, controls, and operational practices Techno Optics LLC follows to protect the confidentiality, integrity, and availability of customer data and the systems that process it. The Policy applies to the Taxottic application and all related infrastructure operated by Techno Optics LLC.

The intended audience is internal personnel (founders, contractors, and any future employees) and external reviewers (security, privacy, and compliance partners, including Plaid).

2. Scope

This Policy covers:

- The Taxottic web application hosted at <https://taxottic.com>.
- The administrative console at <https://hq.taxottic.com>.
- All production data stores, including the Postgres database operated by Supabase.
- Third-party providers handling customer data on our behalf, including Plaid (banking data), Anthropic (transaction-classification AI), Stripe (billing), and Vercel (hosting).
- Any device used by Techno Optics LLC personnel to access production systems.

3. Roles and Responsibilities

Techno Optics LLC is an early-stage company. As of this Policy's effective date, the founder serves as the Information Security Lead and is accountable for:

- Approving and maintaining this Policy.
- Operating the security controls described below.
- Triaging security incidents and notifying affected customers.
- Reviewing and approving access for any new personnel.

When the company grows, this section will be updated to delegate responsibilities to dedicated personnel.

4. Risk Management

The Information Security Lead maintains an informal risk register that lists known threats to customer data and the controls in place to mitigate them. The register is reviewed at least quarterly, and after any material change to the application or infrastructure (new third-party provider, new data category, etc.).

5. Access Control

5.1 Tenant isolation

Every Postgres table that stores customer data has Row-Level Security (RLS) enabled. Policies restrict reads and writes to the company that owns the data. The `bank_connection_secrets` table has RLS enabled with no policies, which means it is reachable only via the service role and never by an authenticated end-user request.

5.2 End-user authentication

End users authenticate to Taxottic through one of:

- Google OAuth (handled by Supabase Auth).
- Microsoft / Azure OAuth (handled by Supabase Auth).
- Passkey / WebAuthn registered to their browser or device.
- One-time email magic link.

Multi-factor authentication is enforced by the OAuth providers' own policies and by passkey hardware. Single-factor magic-link sign-in is available for fallback but is being deprecated in favor of passkey-first onboarding.

5.3 Privileged access

Access to production systems (Vercel, Supabase, GitHub, the Plaid Dashboard) is restricted to the founder. Each provider account requires multi-factor authentication. Service-role keys for Supabase are stored only in Vercel encrypted environment variables and are never committed to source control.

5.4 Periodic access review

Access lists for Vercel, Supabase, GitHub, and Plaid are reviewed at least quarterly by the Information Security Lead. Any unfamiliar account or stale invitation is removed immediately.

5.5 De-provisioning

When personnel leave the company, their access to all production systems is revoked the same business day, and any shared secrets they had visibility into (Vercel env vars, Plaid API keys) are rotated within 30 days.

6. Data Classification and Handling

Taxottic processes the following categories of data:

Category	Examples	Treatment
Authentication identifiers	Email, hashed password (managed by Supabase Auth), passkey credentials	Stored in <code>auth</code> schema managed by Supabase; never logged in plaintext.
Bank access tokens	Plaid <code>access_token</code> per linked Item	AES-256-GCM encrypted at rest in <code>bank_connection_secrets.access_token_enc</code> ; encryption key stored only in Vercel env. Never logged. Never returned to the client.
Transaction data	Posted transaction date, amount, merchant, category	Stored in <code>account_transactions</code> , reachable only by the company that linked the account via RLS.
Profile data	Display name, avatar, company name, address	Stored in <code>profiles</code> , <code>companies</code> tables, reachable only by the user / company members via RLS.
Tax computation inputs	Income, deductions, quarterly safe-harbor estimates	Stored in <code>monthly_income</code> , <code>monthly_expenses</code> ; user-and-company scoped via RLS.

Classification handling rules:

- No category of customer data is sold to third parties.
- No category is shared with third parties except those listed in our public Subprocessor list (<https://taxottic.com/legal/subprocessors>).
- Logs that capture request/response payloads strip authentication identifiers and bank access tokens before write.

7. Encryption

7.1 In transit

All public endpoints are served over TLS 1.2 or better. Vercel terminates TLS 1.3 by default. Supabase enforces TLS 1.2+ for client connections. Server-to-server calls to Plaid (production.plaid.com) use TLS 1.2+ enforced by the Plaid SDK.

7.2 At rest

- Plaid access tokens are encrypted application-side with AES-256-GCM (`lib/crypto/bankTokens.ts`). The encryption key is a 32-byte value stored only in the `BANK_TOKEN_ENC_KEY` Vercel environment variable;

production-tier values are flagged sensitive (write-only via the Vercel CLI).

- All Supabase-managed Postgres data inherits AWS RDS at-rest encryption (AES-256, AWS-managed keys).
- Backups taken by Supabase are encrypted at rest with the same scheme.

8. Vulnerability and Patch Management

- Application dependencies are tracked via `package.json` / `package-lock.json`. `npm audit` is run before every production deploy and surfaced in the Vercel build log.
- GitHub Dependabot is enabled on the repository for security advisories on JavaScript dependencies.
- Postgres engine and Supabase client libraries are kept on supported LTS versions.
- Vercel and Supabase apply infrastructure-level security patches automatically.
- Production deploys go through Vercel. The build log is reviewed for warnings before the deploy is promoted.

Findings rated High or Critical are remediated within 14 days. Medium findings are remediated within 30 days. Lower-severity findings are tracked in the risk register.

9. Webhook and API Security

- The Plaid webhook endpoint at `/api/banks/plaid/webhook` verifies the `Plaid-Verification` JWT against Plaid's published JWKS (ES256), confirms the SHA-256 of the raw request body matches the JWT claim, and rejects any JWT with `iat` older than five minutes (`lib/plaid/webhookVerify.ts`).
- All other API endpoints use Supabase session cookies for authentication and rely on RLS for authorization.

10. Logging and Monitoring

- Vercel captures structured access logs and function invocations. Logs are retained for the duration provided by the Vercel plan in use.
- Supabase captures Postgres logs and authentication events.
- Application errors are surfaced in Vercel logs and reviewed by the Information Security Lead at least weekly and on-demand whenever a customer reports an issue.

11. Incident Response

If a confirmed or suspected security incident affects customer data:

1. The Information Security Lead is notified immediately by any available channel (email, phone, in-person).
2. Affected systems are isolated where possible (e.g., Plaid webhook endpoint disabled, suspicious sessions invalidated).
3. The scope and root cause are determined within 72 hours.

4. Affected customers are notified within 72 hours of confirmation, in writing, including the nature of the incident, the data potentially affected, and the steps being taken.
5. A post-incident review is documented in the risk register, including remediation steps and follow-up controls.

12. Vendor and Third-Party Risk

Before integrating any third-party provider that handles customer data, the Information Security Lead confirms:

- The provider publishes a current SOC 2 Type II report, ISO 27001 certificate, or equivalent.
- The provider's terms allow Techno Optics LLC's intended use.
- A signed Data Processing Addendum (DPA) is in place where required by GDPR or similar law.
- The provider is added to the public subprocessor list at <https://taxottic.com/legal/subprocessors>.

The current subprocessor list is reviewed at least quarterly.

13. Privacy and Consent

- The public Privacy Policy at <https://taxottic.com/legal/privacy> describes what data is collected, why, and how it is used.
- The Terms of Service at <https://taxottic.com/legal/terms> describes the contractual relationship.
- The Data Processing Addendum at <https://taxottic.com/legal/dpa> applies when Taxottic acts as a Processor.
- Users sign an explicit consent before sensitive processing (GDPR consent banner, recorded in the `profiles.gdpr_consented_at` column).
- Users may request deletion of their data by emailing support@taxottic.com. Deletion is performed within 30 days.

14. Data Retention

Category	Retention
Active account data	While the user maintains an active account.
Linked bank connection data	While the connection is active or pending re-auth; deleted within 30 days of user-initiated disconnect.
Auth session records	Per Supabase defaults (60 day refresh token TTL).
Application logs	Per Vercel plan retention defaults; minimum 7 days, maximum 30 days.
Backups	Per Supabase backup retention (point-in-time recovery window of 7 days for the current plan).
Closed-account residual data	Anonymized within 90 days of account closure, except where law requires longer retention.

The retention schedule is reviewed at least quarterly.

15. Acceptable Use

All personnel with access to production systems agree to:

- Use access only for legitimate business purposes.
- Never share credentials or copy sensitive data to personal devices or accounts.
- Lock or sign out of unattended devices.
- Use the company's password manager (or an approved equivalent) for any credential not protected by SSO.
- Report any suspected compromise immediately.

16. Change Management

- All application code changes are made via pull request to the GitHub repository.
- Pull requests are reviewed before merge whenever there is a second contributor available.
- Production deploys happen via push to `main`, which triggers a Vercel build and rollout.
- Database schema changes use Supabase migrations stored in `supabase/migrations/` and are applied via the Supabase MCP / CLI in a deliberate, reviewed step.

17. Policy Review and Update

- This Policy is reviewed at least quarterly by the Information Security Lead.

- The Policy is updated whenever a material change is made to the application, infrastructure, or third-party provider list.
 - Each new version increments the document version, updates the effective date, and is committed to source control under `docs/INFORMATION_SECURITY_POLICY.md`.
-

Signed: Information Security Lead, Techno Optics LLC **Date:** 2026-05-04 **Document version:** 1.0 **Next review:** 2026-08-04